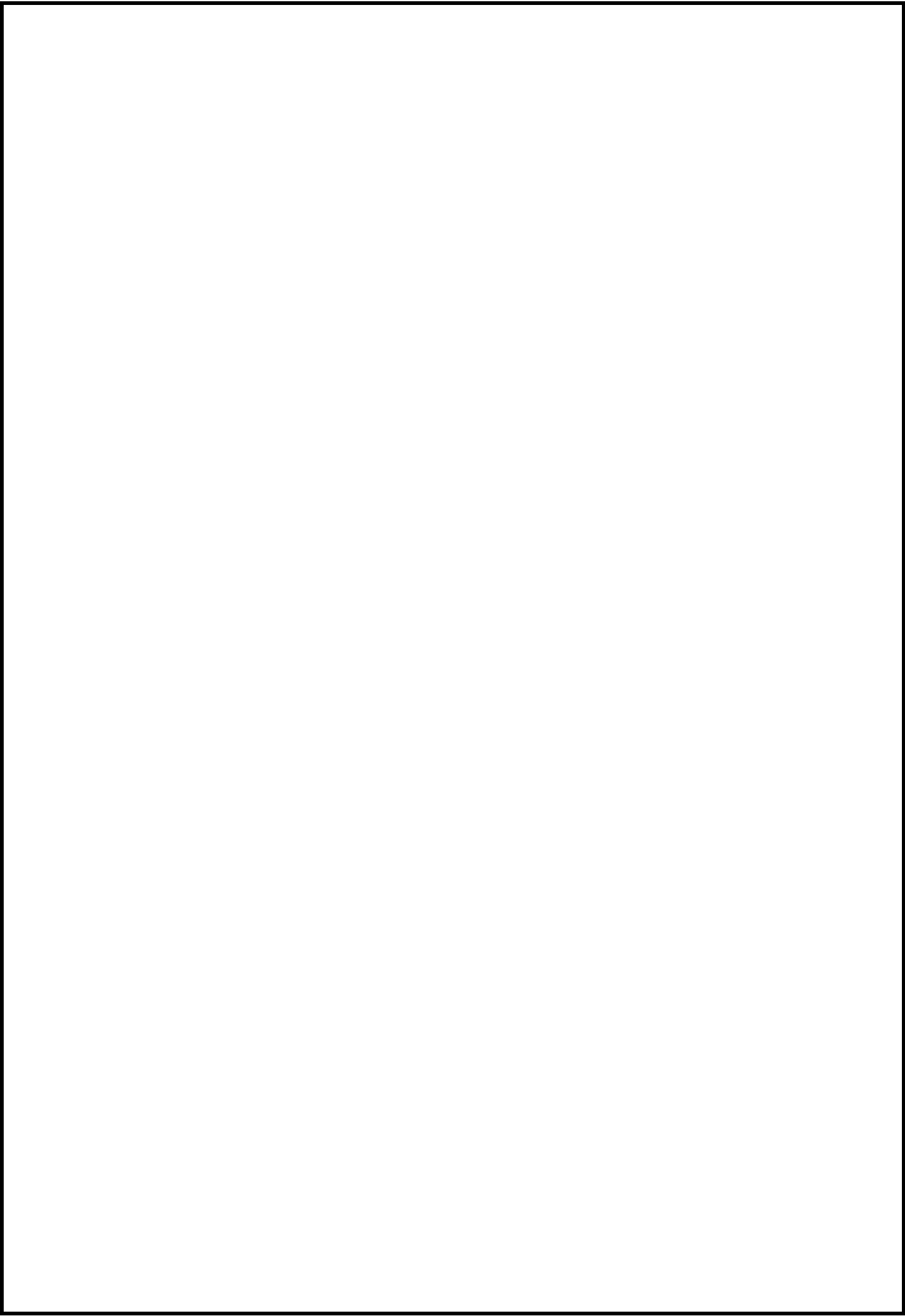


Declaration

I declare that this coursework report is my own original work and has been completed for the ST6050CEM Security Audit and Monitoring module. All testing activities described in this report were conducted within the authorised assessment scope and in a controlled lab environment. The vulnerabilities, evidence, analysis, and recommendations presented in this report are based on the assessment performed against the assigned target system.

I confirm that any external sources, frameworks, standards, tools, screenshots, and references used within this report have been properly acknowledged. This report has been prepared for academic purposes only and must not be used for unauthorised security testing, exploitation, or malicious activity.

Name:	Nirmal Shrestha
Student ID:	15380502
Signature:	<u><i>Nirmal</i></u>
Date:	5 July 2026



Executive Summary

This report evaluates the information security posture of Nepalaya Solutions Pvt. Ltd., a software development company based in Kathmandu that delivers digital solutions for sectors such as healthcare, fintech, and ecommerce. Due to the sensitive nature of the data handled by the organization, weaknesses in access control, system configuration, monitoring, or incident response could create serious operational and compliance risks. The assessment was performed as part of an ISO/IEC 27001:2022-aligned security audit, supported by technical VAPT activities on the assigned audit box and the development of an ITIL-based service management approach.

The audit combined governance review, compliance analysis, vulnerability assessment, penetration testing, and risk-based evaluation. During the technical assessment, several weaknesses were identified, including exposed credentials, insecure authentication behavior, sensitive information disclosure, outdated services, and privilege escalation opportunities. These issues demonstrated how multiple security gaps could be linked together by an attacker to move from initial discovery to unauthorized access and possible system compromise. The findings also showed that stronger logging, alerting, and continuous monitoring would be required to detect suspicious activity at an early stage.

Overall, the assessment shows that Nepalaya Solutions needs to improve both technical controls and security management practices. Priority actions include patching vulnerable components, rotating exposed credentials, enforcing least privilege, hardening configurations, and improving monitoring. These actions will help reduce risk, improve audit readiness, and support long-term security maturity.

1. Introduction

1.1 Organizational Background

Nepalaya Solutions Pvt. Ltd. is a software development company based in Kathmandu, Nepal. The company provides customized digital solutions for sectors such as healthcare, fintech, and ecommerce. As these industries depend heavily on secure data processing, Nepalaya Solutions is responsible for protecting sensitive customer, financial, and business information.

The organization's growing digital operations increase its exposure to cybersecurity threats such as phishing, insecure APIs, weak system configuration, and unauthorised internal access. Because of this, information security must be managed through proper governance, technical controls, monitoring, and continuous improvement. The coursework scenario requires Nepalaya Solutions to conduct an ISO/IEC 27001:2022-aligned external audit, perform VAPT on the provided audit box, and develop an ITIL-based secure service management library

1.2 Purpose of the External Security Audit

The purpose of this external audit is to assess whether Nepalaya Solutions has appropriate security controls to protect its systems, data, and services. The audit helps identify weaknesses in governance, compliance, access control, system configuration, vulnerability management, monitoring, and incident response.

This assessment also supports management decision-making by showing how technical vulnerabilities can create business risks. Instead of only listing weaknesses, the audit explains their causes, impact, priority, and remediation requirements. This helps the organization improve audit readiness and reduce the likelihood of future security incidents.

1.3 Aim and Objectives

The aim of this report is to evaluate the information security posture of Nepalaya Solutions through an ISO 27001-aligned audit and controlled vulnerability assessment.

The main objectives are:

- i. To define an information security governance structure under the role of CISO.
- ii. To identify relevant legal, regulatory, and contractual requirements.
- iii. To apply recognised audit frameworks such as ISO 27001, NIST, COBIT, OWASP, and ITIL.

- iv. To conduct VAPT on the provided audit box using ethical testing methods.
- v. To identify vulnerabilities, assess their risk, and map them to security controls.
- vi. To recommend remediation actions with practical timelines.
- vii. To develop ITIL-based policies for secure service management.

1.4 Scope and Boundaries of Assessment

The scope of this assessment was limited to the authorized virtual audit box provided for Nepalaya Solutions Pvt. Ltd. Testing focused on identifying and validating security weaknesses through controlled reconnaissance, scanning, enumeration, exploitation, post-exploitation, and remediation planning. The assessment was performed ethically within the lab environment and did not include live public systems, third-party infrastructure, or denial-of-service testing. The purpose was to evaluate risk and recommend security improvements, not to disrupt services.

Assessment boundaries included:

- i. Testing was restricted only to the assigned audit box and authorized services.
- ii. No external systems, client networks, or third-party assets were targeted.
- iii. Findings are based on the controlled lab environment and require management review before production implementation.

2. ISO 27001 Governance Framework

2.1 Information Security Governance Structure

For Nepalaya Solutions Pvt. Ltd., information security must be managed as a business-level responsibility rather than only a technical function. Since the company handles sensitive client data across healthcare, fintech, and ecommerce, a clear governance structure is required to define accountability, reporting lines, risk ownership, and monitoring responsibilities.

The governance model is led by the Chief Information Security Officer (CISO), who reports to senior management and provides independent oversight of security risks. This supports ISO 27001:2022 leadership expectations by ensuring that security objectives are aligned with business goals, legal obligations, and client requirements. The coursework also requires the governance structure to be developed under the role of CISO with responsibilities for Security Analyst, Risk Manager, Compliance Officer, and SOC Analyst roles.



Figure 1: Organization Structure

2.2 Roles and Responsibilities

Role	Responsibility
CEO / Board of Directors	Approves security strategy, accepts major risks, and ensures business-level accountability.
CISO	Leads the information security programme, reports risks, manages policies, and ensures ISO 27001 alignment.
Risk Manager	Maintains the risk register, evaluates business impact, and prioritises risk treatment.
Compliance Officer	Reviews legal, regulatory, contractual, and audit requirements.
Security Architect	Designs secure infrastructure, access controls, and hardening standards.
SOC Manager	Manages monitoring, alerting, escalation, and security operations.
DevSecOps Lead	Integrates security checks into development, testing, and deployment.
Security Analyst	Reviews vulnerabilities, validates findings, and supports remediation.
SOC Analyst	Monitors logs, investigates alerts, and reports suspicious activity.
Incident Response Lead	Coordinates containment, evidence collection, recovery, and lessons learned.

Table 1: Roles and Responsibilities

2.3 ISO 27001 Control Alignment

The proposed governance structure supports ISO/IEC 27001:2022 by assigning clear ownership for leadership, risk management, compliance, monitoring, incident response, and secure system development. This is important for Nepalaya Solutions because the organization handles sensitive client data and needs security responsibilities to be managed at both management and operational levels.

The CISO provides overall security direction, while the Risk Manager, Compliance Officer, Security Architect, DevSecOps Lead, SOC Manager, Security Analyst, SOC Analyst, and Incident Response Lead support risk treatment, legal compliance, secure configuration, monitoring, vulnerability management, and incident handling. This improves audit readiness, reduces weak accountability, and supports ISO 27001 principles of leadership, continual improvement, and risk-based security management.

2.4 ISO 27001 Annex Roles Justification

This presents how the proposed information security roles for Nepalaya Solutions Pvt. Ltd. support ISO/IEC 27001:2022 Annex A controls. The mapping shows that each role has a clear security purpose and contributes to governance, risk management, compliance, monitoring, secure development, and incident response.

Role	ISO Alignment	Justification
CEO / Board of Directors	Clause 5, A.5.1, A.5.4	Provides leadership, approves security direction, accepts major risks, and ensures business-level accountability.
CISO	Clause 5, A.5.2, A.5.4	Leads the information security programme, manages policies, reports security risks, and ensures ISO 27001 alignment.
Risk Manager	A.5.4, A.5.7, A.5.8	Maintains the risk register, evaluates business impact, prioritises risk treatment, and supports audit readiness.
Compliance Officer	A.5.31, A.5.32, A.5.33	Reviews legal, regulatory, contractual, and audit requirements to reduce compliance risk.
Security Architect	A.8.20, A.8.22, A.8.25	Designs secure infrastructure, access controls, network protection, and hardening standards.
DevSecOps Lead	A.8.25, A.8.28, A.8.29	Integrates security checks into development, testing, deployment, and secure coding practices.
SOC Manager	A.8.15, A.8.16, A.5.24	Oversees monitoring, alerting, threat detection, escalation, and incident coordination.
Security Analyst	A.8.8, A.8.16, A.5.25	Reviews vulnerabilities, validates findings, supports remediation, and assists incident investigation.
SOC Analyst	A.8.15, A.8.16, A.5.26	Monitors logs, investigates alerts, reports suspicious activity, and supports evidence collection.
Incident Response Lead	A.5.24, A.5.25, A.5.26	Coordinates incident containment, recovery, lessons learned, and post-incident improvement.

Table 2: Roles Justification

2.5 Security Governance Accountability and Escalation Model

Nepalaya Solutions requires a clear accountability and escalation model so that security decisions are not delayed or handled informally. The CISO acts as the central security authority and coordinates risk reporting between technical teams and senior management. Operational teams such as SOC analysts, security analysts, DevSecOps engineers, and incident response personnel identify and report risks, while the Risk Manager and Compliance Officer evaluate business, legal, and regulatory impact. Final approval for major security decisions, risk acceptance, budget allocation, and policy enforcement remains with the CEO and Board of Directors. This ensures that security governance supports ISO/IEC 27001:2022 leadership, accountability, risk ownership, and continual improvement expectations. ISO/IEC 27001 defines requirements for establishing, maintaining, and continually improving an information security management system.

Governance Area	Responsible Role	Accountability Purpose	Evidence Maintained
1. Security Strategy	CEO / Board, CISO	Approves direction, budget, and risk appetite	Security strategy, approval records
2. Risk Management	Risk Manager, CISO	Identifies, evaluates, and prioritises risks	Risk register, treatment plan
3. Compliance	Compliance Officer	Ensures legal, regulatory, and contractual alignment	Compliance checklist, audit evidence
4. Technical Security	Security Architect, DevSecOps Lead	Designs secure architecture and secure development controls	Architecture diagrams, hardening standards
5. Monitoring	SOC Manager, SOC Analyst	Detects suspicious activity and reports incidents	SIEM logs, alert records
6. Vulnerability Management	Security Analyst	Validates findings and supports remediation	Vulnerability reports, retest results
7. Incident Response	Incident Response Lead	Coordinates containment, recovery, and lessons learned	Incident reports, evidence logs

Table 3: Security Governance Accountability

2.6 RACI Matrix for Information Security Roles

A RACI matrix helps Nepalaya Solutions separate responsibility, accountability, consultation, and information-sharing duties. This reduces confusion during audits, incidents, vulnerability remediation, and policy enforcement. It also improves evidence quality because each activity has an assigned owner and reviewer.

Activity	CEO / Board	CISO	Risk Manager	Compliance Officer	Security Analyst	SOC Analyst	Incident Response Lead
Approve Security Policy	A	R	C	C	I	I	I
Maintain Risk Register	I	A	R	C	C	I	I
Review Legal Compliance	I	A	C	R	I	I	I
Conduct Vulnerability Review	I	A	C	I	R	C	I
Monitor Security Events	I	A	I	I	C	R	C
Respond to Incidents	I	A	C	C	C	R	R
Approve Risk Acceptance	A	R	C	C	I	I	I
Report Audit Findings	A	R	C	C	R	C	C

Legend: R = Responsible, A = Accountable, C = Consulted, I = Informed.

Table 4: RACI Matrix

3. Legal, Regulatory and Contractual Compliance

3.1 Legal and Regulatory Requirements

As Nepalaya Solutions Pvt. Ltd. is registered in Nepal, it must comply with relevant Nepalese laws, cybersecurity requirements, privacy expectations, and contractual obligations. These requirements define how organisational data should be collected, stored, processed, accessed, and protected. Since the audit identified weaknesses such as weak authentication, credential exposure, privilege escalation, and insecure service access, legal and contractual compliance is important for reducing risk and maintaining client trust.

- i. The Electronic Transactions Act 2006 is a key legal foundation for electronic records and cyber-related activities in Nepal. It supports the need to prevent unauthorised access, protect information, and maintain accountability if cyber incidents occur.
- ii. The Privacy Act 2018 and related data protection requirements focus on protecting personal and sensitive information. Weak access control, exposed credentials, and poor monitoring could lead to privacy breaches, reputational damage, and compliance issues.
- iii. Nepalaya Solutions should also consider relevant cybersecurity directives and organisational security policies to ensure systems are monitored, updated, and protected

against misuse. Findings such as outdated services and insecure configurations show the need for continuous vulnerability management.

- iv. For international clients, global privacy requirements such as GDPR should be considered where personal data is processed. GDPR expects strong authentication, access control, logging, monitoring, and breach response controls.
- v. Contractual requirements from clients must also be followed. These may include secure development practices, confidentiality, incident reporting, service availability, vulnerability remediation, and protection of client data.

3.2 Contractual and Client Security Obligations

Apart from legal requirements, Nepalaya Solutions must also meet the security obligations agreed with its clients, especially those from regulated sectors such as healthcare, fintech, and ecommerce. These obligations may include secure software development, protection of source code and client data, access control, vulnerability management, incident reporting, confidentiality, and regular security testing. The audit findings show that weaknesses such as exposed credentials, weak authentication, outdated services, or privilege escalation could lead to data exposure, service disruption, unauthorised administrative access, breach of service agreements, financial penalties, contract termination, and reputational damage.

3.3 Compliance Risk and Audit Readiness

The vulnerabilities identified during the assessment show that technical weaknesses can become compliance and audit risks. Issues such as credential exposure, privilege escalation, outdated services, and weak logging may cause unauthorised access, data exposure, and delayed incident detection. To improve audit readiness, Nepalaya Solutions should maintain updated policies, risk registers, patch records, incident logs, vulnerability reports, and remediation evidence aligned with legal, contractual, and ISO 27001 expectations.

3.4 Legal, Regulatory, and Contractual Compliance Mapping

The compliance assessment was mapped against relevant Nepalese laws, cybersecurity expectations, international privacy requirements, and client contractual obligations. This mapping ensures that technical findings from the audit are not treated only as system weaknesses, but also as possible legal, regulatory, and contractual risks. The Electronic Transactions Act, 2063 is relevant because it provides Nepal's legal basis for electronic transactions and computer-related offences. The Privacy Act, 2075 is relevant because

Nepalaya Solutions processes sensitive personal and client information. The National Cyber Security Policy, 2080 supports national-level cybersecurity expectations and strengthens the relevance of secure infrastructure, incident response, and cyber resilience.

Law / Standard / Obligation	Relevance to Nepalaya Solutions	Audit Requirement	ISO/IEC 27001:2022 Mapping
Electronic Transactions Act, 2063	Relevant to electronic records, digital transactions, unauthorised access, and cyber misuse	Ensure systems are protected from unauthorised access, misuse, and evidence tampering	A.5.31, A.5.32, A.8.15, A.8.16
Privacy Act, 2075	Relevant because the company handles personal, customer, healthcare, and business data	Protect personal data using access control, confidentiality, logging, and secure storage	A.5.34, A.8.10, A.8.11, A.8.12
National Cyber Security Policy, 2080	Relevant for cybersecurity readiness, national cyber resilience, and secure digital services	Improve prevention, detection, response, and recovery capability	A.5.24, A.5.25, A.5.30
GDPR	Relevant if Nepalaya Solutions processes EU client or customer data	Ensure lawful processing, privacy-by-design, breach response, and data protection controls	A.5.34, A.8.11, A.8.12
Client Contracts / SLA / NDA	Relevant to confidentiality, service availability, incident reporting, and secure delivery	Meet agreed security obligations and avoid breach of contract	A.5.19, A.5.20, A.5.23
Sector Expectations: Fintech / Healthcare / Ecommerce	Relevant due to high-risk data and service dependency	Maintain stronger access control, monitoring, secure development, and incident response	A.5.15, A.8.20, A.8.25

Table 5: Mapping

4. Audit Framework and Methodology

4.1 Integrated Audit Approach

The audit of Nepalaya Solutions was conducted using an integrated approach that combined governance review, compliance assessment, technical testing, risk analysis, and service management improvement. ISO/IEC 27001:2022 was used as the main framework because it supports risk-based information security management, control ownership, leadership accountability, and continual improvement.

Additional frameworks were also considered to strengthen the audit. NIST supported technical control review and risk assessment, COBIT supported governance and business alignment, OWASP supported web application security testing, and ITIL supported incident management, change management, monitoring, and business continuity. This combined approach ensured that the audit was not limited to technical vulnerabilities only, but also considered organizational risk, compliance, and operational resilience.

4.2 Audit Methodology

The audit methodology followed a simple risk-based process: planning, fieldwork, control testing, reporting, and follow-up. First, the audit scope, objectives, boundaries, and evidence requirements were defined. Then reconnaissance, scanning, enumeration, and evidence collection were performed on the authorized audit box. Identified weaknesses were validated through controlled testing, documented with risk ratings and business impact, and followed by remediation and retesting recommendations to support ISO 27001-aligned continuous improvement.

4.3 Audit Lifecycle

The audit lifecycle followed a structured process from planning to improvement. First, the audit scope, objectives, authorised environment, and testing boundaries were defined. Then the assessment moved into reconnaissance, scanning, enumeration, vulnerability validation, exploitation, and evidence collection. After the technical work, findings were analyzed using risk rating, business impact, and framework mapping. Finally, remediation actions and follow-up recommendations were prepared to support continuous improvement.



Figure 2: Audit Life Cycle

4.4 Framework Alignment and Control Validation

The audit used multiple frameworks to make the assessment complete and reliable. ISO/IEC 27001:2022 was used as the main framework for governance, leadership, risk management, and control alignment, while NIST supported technical control review, COBIT supported business governance, OWASP supported web application security testing, and ITIL supported incident management, change management, monitoring, and service continuity. This helped Nepalaya Solutions connect technical vulnerabilities with business risk, compliance expectations, control weaknesses, and remediation priorities.

4.5 Ethical and Controlled Testing

All testing activities were performed only within the authorised audit box provided for the coursework, and no live public systems, third-party infrastructure, client networks, or unauthorised assets were targeted. The purpose of testing was to safely validate security weaknesses, understand their possible impact, and collect evidence through screenshots, command outputs, scan results, and controlled exploitation proof. This ensured that the findings were accurate, reproducible, ethical, and suitable for remediation planning and retesting.

4.6 Framework Integration and Audit Application Matrix

Framework	Purpose in Audit	How It Was Applied	ISO/IEC 27001:2022 Alignment
ISO/IEC 27001:2022	Main ISMS and audit framework	Used for governance, leadership, risk treatment, control mapping, and continual improvement	Clause 4, Clause 5, Clause 6, Clause 9.2, Annex A
NIST SP 800-53	Technical control reference	Used to review access control, logging, vulnerability management, configuration, and incident response	A.5.15, A.8.8, A.8.15, A.8.16
COBIT	IT governance and business alignment	Used to connect security risks with accountability, management reporting, and business impact	Clause 5, A.5.4, A.5.35
OWASP WSTG	Web application and API security testing	Used to guide authentication, authorization, input validation, and configuration testing	A.8.25, A.8.26, A.8.28
ITIL	Secure IT service management	Used to support incident management, change management, asset management, and service continuity	A.5.24, A.5.25, A.5.30, A.5.32

Table 6: Matrix

4.7 ISO 27001 Internal Audit Clause 9.2 Alignment

The audit methodology was aligned with ISO/IEC 27001:2022 Clause 9.2, which focuses on internal audit planning, audit criteria, scope, reporting, and follow-up. Although this assessment was performed as an external coursework audit, the same audit discipline was applied by defining the assessment scope, documenting the audit criteria, collecting evidence, validating findings, reporting risks, and recommending corrective actions. This approach ensures that the audit remains structured, repeatable, evidence-based, and useful for management decision-making.

ISO 27001 Audit Requirement	Application in This Audit
Define audit scope	Testing was limited to the authorised audit box
Define audit criteria	ISO 27001, NIST, COBIT, OWASP, ITIL, and legal obligations were used
Collect audit evidence	Screenshots, logs, scan outputs, and command results were recorded
Evaluate control effectiveness	Findings were mapped to failed or weak controls
Report audit results	Risks, impact, root cause, and remediation were documented
Follow-up actions	Retesting and continuous improvement recommendations were included

Table 7: Alignment

5. VAPT Tools, Techniques and Procedures

5.1 Testing Approach

The Vulnerability Assessment and Penetration Testing activity was performed on the authorised audit box provided for Nepalaya Solutions Pvt. Ltd. using a controlled black-box testing approach, where the tester initially had no internal knowledge of the target system. The purpose was to simulate how an external or unauthorised attacker could identify exposed services, enumerate resources, validate weaknesses, and chain vulnerabilities to gain system access. The testing combined automated scanning with manual validation to reduce false positives and confirm real-world impact. This approach aligns with the coursework requirement to demonstrate system and penetration testing using appropriate tools, techniques, and procedures. ISO/IEC 27001:2022 was used as the main governance and control reference for risk-based security management, while NIST SP 800-53 supported technical control review for access control, monitoring, configuration, vulnerability management, and incident response.

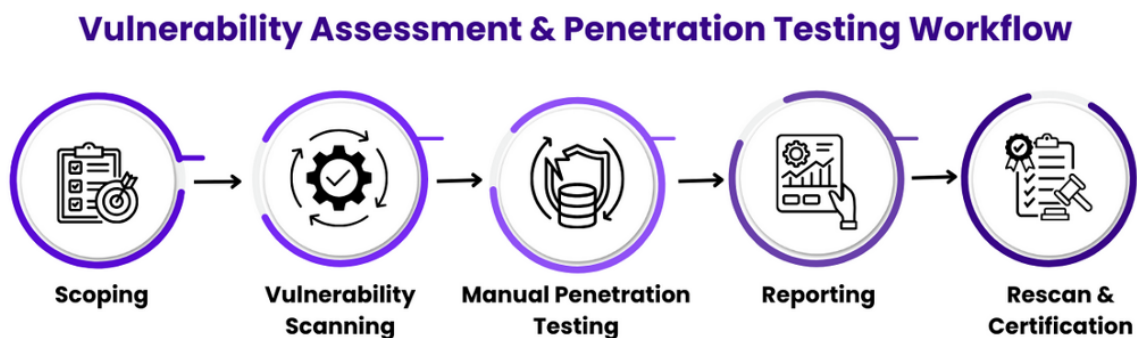


Figure 3: Testing Workflow

5.2 Scope and Testing Boundary

The scoping phase defined what was included and excluded from the assessment before any technical testing was performed. The VAPT activity was limited to the authorised audit box provided for Nepalaya Solutions Pvt. Ltd. and was conducted only inside the controlled lab environment. No public systems, third-party infrastructure, client networks, or denial-of-service testing were included. This ensured that the assessment remained ethical, controlled, and aligned with the approved coursework requirements.

5.3 Vulnerability Scanning

The Nmap scan identified exposed services including SSH on port 22, HTTP on port 80, and an additional web service on port 8082. These results were important because they showed that the target system had both remote access and web application services available for further testing. The SSH service later became relevant during credential compromise validation, while the web services supported directory enumeration and application-level vulnerability testing.

```
(ox033@ox033)-[~]
└─$ nmap -p- --min-rate 500 192.168.144.84 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 00:35 +0545
Nmap scan report for 192.168.144.84
Host is up (0.080s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
8082/tcp  open  http     nginx 1.14.2
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 74.52 seconds
```

Figure 4: Nmap scan

The Feroxbuster scan identified multiple accessible web paths and resources. This confirmed that the web application had discoverable directories and files that could assist an attacker in understanding the application structure. These results supported later manual testing, including exposed file review, credential discovery, and application validation.

```

(ox033@ox033)~$ feroxbuster --url http://192.168.144.84/ -C 403,404,500,401,301

FERROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url      http://192.168.144.84/
In-Scope Url    192.168.144.84
Threads         50
Wordlist        /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Code Filters [403, 404, 500, 401, 301]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 279c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 9l 31w 276c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 3l 4w 28c http://192.168.144.84/cms/cache/bigtree-module-class-list.json
200 GET 1l 1w 4c http://192.168.144.84/cms/cache/composer-check.flag
200 GET 947l 5821w 407824c http://192.168.144.84/file.jpg
200 GET 8l 15w 164c http://192.168.144.84/
200 GET 2990l 7827w 94053c http://192.168.144.84/cms/cache/site.css
200 GET 17l 2055w 140544c http://192.168.144.84/cms/cache/site.js
200 GET 0l 0w 0c http://192.168.144.84/cms/custom/settings.php
200 GET 0l 0w 0c http://192.168.144.84/cms/custom/environment.php
200 GET 6l 102w 8415c http://192.168.144.84/cms/site/js/jquery.slicknav.min.js
200 GET 60l 95w 1389c http://192.168.144.84/cms/site/js/main.js
200 GET 68l 156w 1959c http://192.168.144.84/cms/site/js/WaveSurferInit.js
200 GET 115l 258w 2799c http://192.168.144.84/cms/site/js/jplayerInit.js
200 GET 79l 1349w 13484c http://192.168.144.84/cms/core/setup/base.sql
200 GET 0l 0w 0c http://192.168.144.84/cms/core/setup/environment.php
200 GET 0l 0w 0c http://192.168.144.84/cms/core/setup/settings.php
200 GET 12l 4157w 43790c http://192.168.144.84/cms/core/setup/example-site.sql

```

Figure 5: Fuzzing

```

(ox033@ox033)~$ nuclei -target http://192.168.248.84

projectdiscovery.io v3.7.1

[INF] Current nuclei version: v3.7.1 (outdated)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 10447
[INF] Executing 10430 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 17 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2389 (Reduced 2256 Requests)
[INF] Using Interactsh Server: oast.site
[phpinfo-files] [http] [low] http://192.168.248.84/info.php ["7.3.14"] [paths="/info.php"]
[waf-detect:apachegeneric] [http] [info] http://192.168.248.84
[eol-openssh-debian] [javascript] [medium] 192.168.248.84:22 ["SSH-2.0-OpenSSH_7.9p1 Debian-10+deb10u2"]
[ssh-sha1-hmac-algo] [javascript] [info] 192.168.248.84:22
[CVE-2023-48795] [javascript] [medium] 192.168.248.84:22 ["Vulnerable to Terrapin"]
[ssh-server-enumeration] [javascript] [info] 192.168.248.84:22 ["SSH-2.0-OpenSSH_7.9p1 Debian-10+deb10u2"]
[ssh-password-auth] [javascript] [info] 192.168.248.84:22
[ssh-auth-methods] [javascript] [info] 192.168.248.84:22 ["["publickey","password"]"]
[openssh-detect] [tcp] [info] 192.168.248.84:22 ["SSH-2.0-OpenSSH_7.9p1 Debian-10+deb10u2"]
[CVE-2026-25892:version] [http] [high] http://192.168.248.84/adminer.php ["4.7.7"]
[options-method] [http] [info] http://192.168.248.84 ["HEAD,GET,POST,OPTIONS"]
[adminer-panel] [http] [info] http://192.168.248.84/adminer.php ["4.7.7"]

```

Figure 6: Nuclei vulnerability scanning

5.4 Manual Penetration Testing

Manual penetration testing was performed after scanning to confirm whether the identified weaknesses were exploitable. This step was important because automated scanning alone may produce false positives or may not fully explain business impact. Manual testing was used to validate insecure password reset behavior, exposed credentials, database access through

Adminer, SSH credential compromise, and privilege escalation through insecure script permissions. Each test was performed only within the authorised audit box and evidence was collected through screenshots and command outputs.

5.5 Reporting

After scanning and manual validation, all confirmed findings were documented with affected asset, severity, CVSS score, evidence, impact, ISO/IEC 27001:2022 mapping, legal compliance relevance, and remediation guidance. The reporting phase converted technical results into business risk so Nepalaya Solutions could prioritize fixes, assign responsible owners, and plan retesting.

5.6 Tools Used

Tool	Purpose	How It Was Used in This Assessment
Nmap	Network scanning and service detection	Used to identify open ports, running services, and software versions on the authorised audit box. The scan helped confirm exposed services such as SSH and HTTP, which guided further enumeration and testing.
Feroxbuster	Web directory and file enumeration	Used to discover hidden directories, files, and exposed web resources within the web application. The results helped identify accessible paths that supported later manual validation and information disclosure findings.
Nuclei	Automated vulnerability and misconfiguration scanning	Used to scan the target against known vulnerability templates and misconfiguration checks. The scan identified exposed components such as info.php, Adminer, OpenSSH version details, SSH authentication methods, and Terrapin-related SSH weakness indicators.

Figure 7: Tools used

6. Overview Of Findings

Finding ID	Vulnerability	Category	Severity	CVSS	Business Impact
C-1	MantisBT Pre-Authentication Password Reset Vulnerability	Authentication / Account Takeover	Critical	9.8	Unauthorised account takeover, access to sensitive application functions, and possible disclosure, modification, or destruction of application data.
H-1	Privilege Escalation via Writable check-system Script	Privilege Escalation / Insecure Permissions	High	8.2	Low-privileged access could be escalated to root-level control, leading to full system compromise and loss of confidentiality, integrity, and availability.
H-2	Plaintext Credential Disclosure	Sensitive Information Disclosure	High	7.5	Exposed administrative credentials could allow unauthorised access to application resources, database functions, and sensitive business information.
H-3	SSH Credential Compromise	Credential Compromise / Unauthorised Access	High	8.8	Recovered SSH credentials could provide authenticated shell access, enabling reconnaissance, persistence, privilege escalation, and further compromise.

Table 8: Findings

7. Detailed Findings

H-1: PRIVILEGE ESCALATION VIA WRITABLE CHECK-SYSTEM SCRIPT

Risk Rating: High



DESCRIPTION

A privileged script named `check-system` was configured with insecure write permissions. A low-privileged user was able to modify the script and insert malicious commands. Upon execution, the script granted elevated privileges, ultimately resulting in root-level access.

Privilege Escalation via Writable check-system Script	
Impact	An attacker with low-privileged access can modify a privileged system script and execute arbitrary commands with elevated permissions. Successful exploitation may result in complete system compromise and root-level access.
Likelihood	High
Risk Rating	High
CVSS Score	8.2 (CVSS:3.1/AV:L/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H)
Affected URL	N/A
ISO/IEC 27001:2022	A.5.15 Access control, A.5.18 Access rights, A.8.2 Privileged access rights, A.8.3 Information access restriction
Legal Compliance	Electronic Transactions Act 2063, Privacy Act 2075, and client security obligations for unauthorised access prevention and system integrity

EVIDENCE

The check-system script was found writable by the compromised user. The script was modified to add a SUID bit to /bin/bash and was executed after system restart, resulting in root access.

STEPS TO REPRODUCE

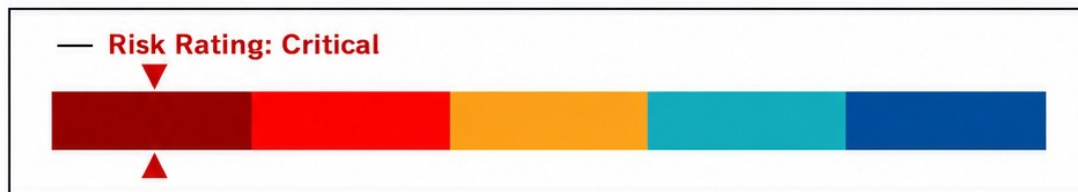
1. Obtain low-privileged shell access to the target system.
2. Enumerate writable files and identify the privileged check-system script.
3. Review the script and confirm that the current user can modify it.
4. Insert a command into the script to add the SUID bit to `/bin/bash`.
5. Trigger execution of the modified script by restarting the system or allowing the script to run.
6. Execute `/bin/bash -p` to obtain a root shell.

REMEDIATION

- Restrict write permissions on privileged scripts.
- Apply the principle of least privilege.
- Implement file integrity monitoring.
- Review and harden ownership and permission settings for all scripts executed with elevated privileges.

Figure 8: Privilege Escalation

C-1: MANTISBT PRE-AUTHENTICATION PASSWORD RESET VULNERABILITY



DESCRIPTION

The target application was running a vulnerable version of MantisBT that allowed attackers to reset user passwords without prior authentication. Successful exploitation could result in complete compromise of user accounts and unauthorised access to sensitive application functionality.

MantisBT Pre-Authentication Password Reset Vulnerability	
Impact	An attacker can reset passwords of valid users without authentication, resulting in unauthorised account takeover and access to sensitive application functionality. Successful exploitation may lead to disclosure, modification, or destruction of application data.
Likelihood	High
Risk Rating	Critical
CVSS Score	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected URL	http://192.168.172.84/mantisbt/verify.php?id=1&confirm_hash=
ISO/IEC 27001:2022	A.5.15 Access control, A.5.16 Identity management, A.5.17 Authentication information, A.8.5 Secure authentication, A.8.8 Management of technical vulnerabilities
Legal Compliance	Electronic Transactions Act 2063, Privacy Act 2075, GDPR where applicable, and client contractual obligations for preventing unauthorised access and account compromise

EVIDENCE

The password reset function was abused without authentication. The administrator password was changed and the account was accessed using the changed credentials. Evidence should be included in Appendix I.

STEPS TO REPRODUCE

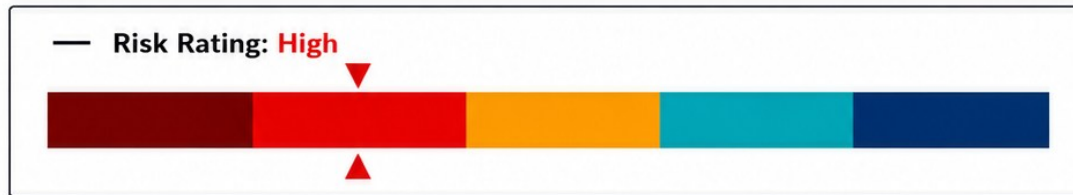
1. Browse to the vulnerable MantisBT password reset endpoint within the authorised audit box.
2. Submit a reset request for a valid user account without authenticating.
3. Change the password using the vulnerable reset function.
4. Log in to the application using the changed password.
5. Record screenshots showing password change and successful account access.

REMEDIATION

- Apply the latest vendor security patches for MantisBT.
- Enforce secure password reset token generation, expiry, and validation.

Figure 9: Pre-Auth Password Reset Vulnerability

H-2: PLAINTEXT CREDENTIAL DISCLOSURE



DESCRIPTION

Administrative credentials were discovered exposed in plaintext within application resources. An attacker obtaining these credentials could gain unauthorised access to administrative functionality and potentially compromise additional systems.

Plaintext Credential Disclosure	
Impact	Exposure of administrative credentials allows attackers to gain unauthorised access to application resources and sensitive information. Compromised credentials may facilitate further compromise of the target environment.
Likelihood	High
Risk Rating	High
CVSS Score	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Affected URL	http://192.168.172.84/mantisbt/config/a.txt
ISO/IEC 27001:2022	A.5.15 Access control, A.5.17 Authentication information, A.8.9 Configuration management, A.8.11 Data masking, A.8.12 Data leakage prevention
Legal Compliance	Electronic Transactions Act 2063, Privacy Act 2075, GDPR where applicable, SLA/NDA obligations, and secure handling of confidential client information

EVIDENCE

Valid credentials were identified during application enumeration. The exposed credentials provided access to administrative resources. Evidence should be included in Appendix I.

STEPS TO REPRODUCE

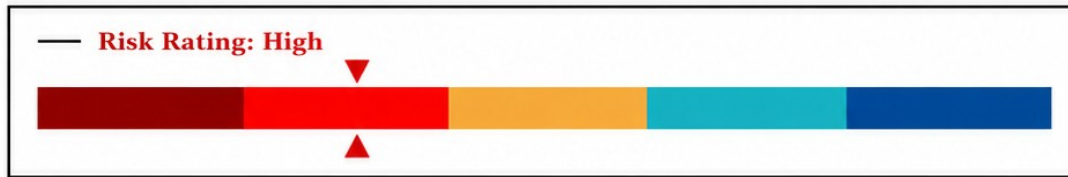
1. Enumerate exposed web directories and application files within the authorised audit box.
2. Locate the accessible configuration file containing plaintext credentials.
3. Review the file content and confirm that credentials are exposed.
4. Use the disclosed credentials only within the authorised scope to validate administrative access.
5. Capture evidence showing the exposed file and successful authorised validation.

REMEDIATION

- Remove hardcoded credentials from application files.
- Rotate all exposed passwords immediately.

Figure 10: Credentials Disclosure

H-3: SSH CREDENTIAL COMPROMISE



DESCRIPTION

Valid SSH credentials were obtained during the assessment and successfully used to authenticate to the target system. This vulnerability provided an initial foothold and enabled further post-exploitation activities.

SSH Credential Compromise	
Impact	Valid SSH credentials enable attackers to obtain authenticated access to the target system, providing a foothold for reconnaissance, privilege escalation, persistence, and further attacks.
Likelihood	High
Risk Rating	High
CVSS Score	8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
Affected Service	SSH service on port 22
ISO/IEC 27001:2022	A.5.15 Access control, A.5.16 Identity management, A.5.17 Authentication information, A.8.2 Privileged access rights, A.8.5 Secure authentication
Legal Compliance	Electronic Transactions Act 2063, Privacy Act 2075, client SLA/NDA obligations, and confidentiality requirements for preventing unauthorised system access

EVIDENCE

SSH credentials were found inside the database through adminer.php. The recovered credentials authenticated successfully against the SSH service and remote shell access was established. Credentials should be masked in the final report.

STEPS TO REPRODUCE

1. Review authorised application/database access obtained during the assessment.
2. Identify stored SSH credentials within the database or application records.
3. Validate the SSH service availability on the target system.
4. Authenticate to SSH using the recovered credentials within the authorised audit scope.
5. Capture evidence of successful shell access while masking sensitive credentials.

REMEDIATION

- Reset compromised SSH credentials immediately.
- Enforce strong password policies and key-based authentication requirements.
- Restrict database and application access to authorised personnel only.
- Store sensitive credentials securely using encryption and secrets management solutions.
- Monitor and audit access to detect and prevent future credential exposure.

Figure 11: SSH compromise

8. Vulnerability Remediation and Management Response

The detailed findings show that Nepalaya Solutions faces high-risk weaknesses related to authentication, credential exposure, SSH access, and privilege escalation. Since these vulnerabilities can be chained together to support unauthorised access and possible full system compromise, remediation must be prioritized based on severity, business impact, and exploitability. The following remediation plan assigns clear owners, timelines, expected evidence, and company response requirements so that each issue can be tracked, fixed, retested, and formally closed.

8.1 Prioritized Remediation Action Plan

Priority	Finding	Action Required	Owner	Timeline
1	MantisBT Password Reset	Patch MantisBT and secure password reset token validation	DevSecOps Lead	24–48 hours
2	Plaintext Credential Disclosure	Remove exposed files and rotate all exposed credentials	Application Owner	24 hours
3	SSH Credential Compromise	Reset SSH credentials, restrict SSH access, and review logs	System Administrator	24–48 hours
4	Writable check-system Script	Correct file permissions, review ownership, and apply least privilege	System Administrator	3–7 days

Table 9: Prioritized Action Plan

9. Framework Selection

Framework selection ensures the audit uses recognized standards to assess governance, technical controls, web security, risk ownership, and service management, making findings more reliable, structured, and remediation focused.

Framework	Reason for Selection	Relevance to This Audit
ISO/IEC 27001:2022	Main ISMS and audit control framework	Used to map findings to access control, authentication, vulnerability management, monitoring, incident response, and business continuity controls
NIST SP 800-53	Technical security control reference	Used to support technical assessment of identity, access control, configuration, vulnerability management, and monitoring weaknesses
OWASP WSTG / OWASP Top 10	Web application security reference	Used to classify authentication weakness, sensitive information disclosure, and security misconfiguration
COBIT	IT governance and business alignment framework	Used to connect technical vulnerabilities with accountability, risk ownership, business impact, and management decision-making
ITIL	IT service management framework	Used to develop policies and procedures for incident management, change management, risk treatment, monitoring, and recovery

Table 10: Framework selection

9.1 Security Control Mapping

Vulnerability	ISO 27001:2022	NIST	OWASP	COBIT	Justification
MantisBT Password Reset	A.5.15 Access Control A.5.16 Identity Mgmt A.5.17 Auth Info A.8.5 Secure Auth	IA-2 IA-5	A07 Auth Failures	DSS05 APO13	Weak reset control can cause account takeover and unauthorised access.
Writable check-system Script	A.5.18 Access Rights A.8.2 Privileged Access A.8.9 Config Mgmt	AC-6 CM-6	A05 Security Misconfig	DSS05 BAI06	Insecure permissions can allow privilege escalation to root.
Plaintext Credential Disclosure	A.5.17 Auth Info A.8.11 Data Masking A.8.12 Data Leakage	IA-5 CM-6	A02 Crypto Failures A05 Misconfig	DSS05	Exposed credentials can allow access to sensitive resources.
SSH Credential Compromise	A.5.15 Access Control A.5.16 Identity Mgmt A.8.2 Privileged Access A.8.5 Secure Auth	IA-2 IA-5 AC-6	A07 Auth Failures	DSS05	Recovered SSH credentials can provide shell access.
Outdated / Exposed Services	A.8.8 Technical Vulns A.8.9 Config Mgmt A.8.20 Network Security	SI-2 CM-8	A05 Misconfig A06 Vulnerable Components	DSS05 BAI09	Exposed services increase attack surface and exploitation risk.

Table 11: Security Control Mapping

10. ITIL-Based Secure Service Management Library

This section presents an ITIL-based secure service management library for Nepalaya Solutions Pvt. Ltd. The library has been developed to convert the audit and VAPT findings into practical operational controls, policies, and procedures. The technical assessment identified weaknesses related to authentication, credential exposure, SSH access, privilege escalation, and monitoring. Therefore, the ITIL library focuses on improving incident handling, change control, access management, risk treatment, monitoring, logging, and business continuity. This supports long-term security improvement by ensuring that vulnerabilities are not only fixed technically but also managed through repeatable service management processes.

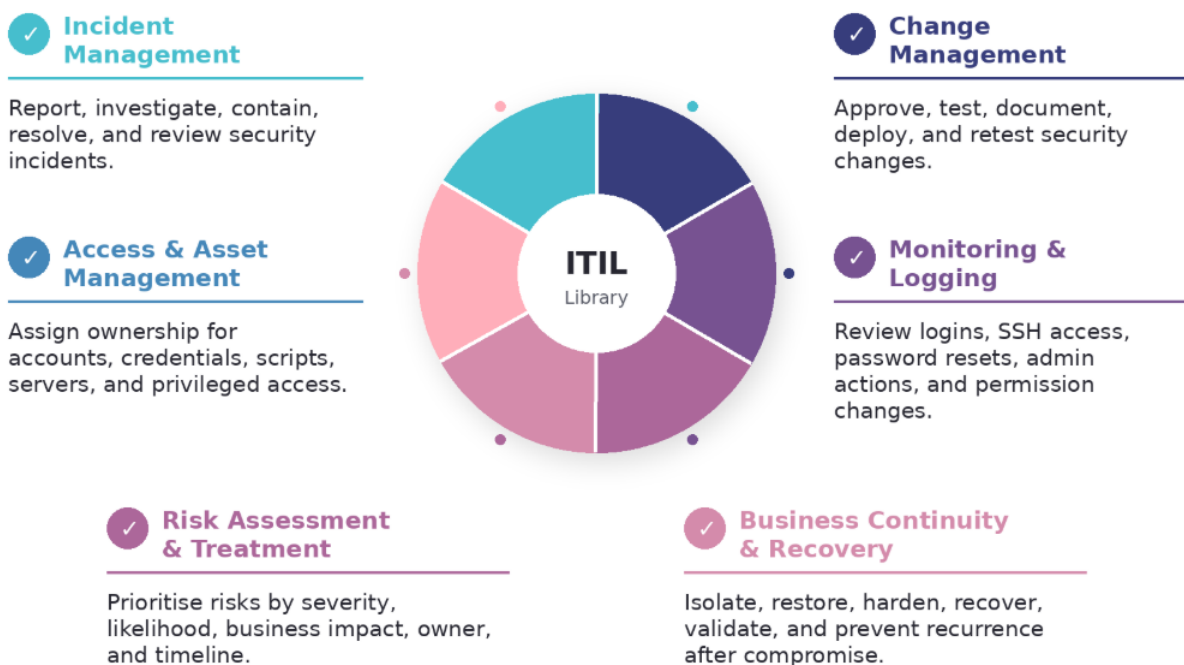


Figure 12: ITIL Secure Service Management Service

9.1 ITIL Library Coverage

ITIL Policy Area	Purpose	Related Audit Risk
Incident Management	Detect, report, investigate, contain, recover, and review security incidents.	Account compromise, SSH misuse, privilege escalation.
Change Management	Ensure system changes are reviewed, approved, tested, implemented, and documented.	Misconfiguration, insecure patching, vulnerable services.
Access Control and Asset Management	Maintain ownership of accounts, assets, credentials, and privileged access.	Plaintext credentials, excessive access, weak asset ownership.
Risk Assessment and Treatment	Identify, evaluate, prioritise, treat, and review information security risks.	Critical and high-risk vulnerabilities.
Monitoring and Logging	Record and review security events to detect suspicious behaviour early.	Weak detection of password reset abuse, SSH access, and privilege misuse.
Business Continuity and Recovery	Maintain service availability and restore systems after incidents or compromise.	System compromise, data loss, and service disruption.

Table 12: ITIL coverage